

Step 1:

Field	Value
Step	1
Module	RECON
Hypothesis	Identify exposed services and technologies
Action	nmap -sV -sC -p 8081 100.113.75.28
Outcome	Success
Pivot?	No
Notes	Apache 2.4.65, DVWA custom build, robots.txt entries discovered

Step 2:

Field	Value
Step	2
Module	ENUMERATION
Hypothesis	Directory discovery may reveal sensitive endpoints
Action	Gobuster directory scan
Outcome	Success
Pivot?	Yes
Notes	setup.php, php.ini, instructions.php, view_source.php discovered

Step 3:

Field	Value
Step	3
Module	AUTH

Hypothesis	Default DVWA credentials may grant admin access
Action	Login with admin/password
Outcome	Success
Pivot?	Yes
Notes	Authenticated session established

Step 4:

Field	Value
Step	4
Module	SQLI
Hypothesis	Hidden role=admin parameter disables WAF for SQL injection
Action	UNION-based SQLi with role=admin & debug=1
Outcome	Success (enumeration)
Pivot?	No
Notes	Backdoor confirmed; full query visibility obtained

Step 5:

Field	Value
Step	5
Module	SQLI
Hypothesis	Flag stored in database tables
Action	Enumerate information_schema tables
Outcome	Fail (no flag table found)
Pivot?	Yes

Notes	Tables: access_log, guestbook, security_log, users — no flag present
-------	--

Step 6:

Field	Value
Step	6
Module	SQLI
Hypothesis	Use LOAD_FILE() to read filesystem via SQL
Action	Attempt LOAD_FILE('/path/to/file')
Outcome	Fail
Pivot?	Yes
Notes	secure_file_priv restriction prevents file reads

Step 7:

Field	Value
Step	7
Module	UPLOAD
Hypothesis	Upload PHP webshell disguised as image
Action	Upload \x00PNG forged magic byte + .pht extension
Outcome	Success
Pivot?	Yes
Notes	Uploaded to hackable/uploads/custom_xxx/img_shell.pht

Step 8:

Field	Value
Step	8
Module	LFI
Hypothesis	Double URL encoding bypasses str_replace('..') filter
Action	page=..%252F..%252Fhackable/.../img_shell.pht
Outcome	Success
Pivot?	Yes
Notes	RCE achieved as www-data via include()

Step 9:

Field	Value
Step	9
Module	RCE
Hypothesis	Flag located on filesystem outside webroot
Action	Filesystem search via PHP shell
Outcome	Success
Pivot?	No
Notes	/foothold/flag.txt identified

Step 10:

Field	Value
Step	10
Module	POST-EXPLOIT

Hypothesis	/foothold/flag.txt contains FLAG{}
Action	file_get_contents('/foothold/flag.txt')
Outcome	Success
Pivot?	No
Notes	FLAG{INITIAL_FOOTHOLD_ACHIEVED} retrieved

Metrics:

Total steps: 10

Total pivots: 5

Dead-end modules: 1

Exploit chain depth: 4

Success: yes